



**IN THE MATTER OF THE ALLEGED
PERSONAL DATA BREACH OF BDO
UNIBANK, INC.,**

NPC SS 21-023

INITIATED AS A *SUA SPONTE* NPC
INVESTIGATION ON POSSIBLE DATA
PRIVACY VIOLATIONS COMMITTED
IN RELATION TO THE ALLEGED
HACKING OF BDO UNIBANK INC.
CLIENT ACCOUNTS

For: Violation of the
Data Privacy Act of
2012

X-----X

DECISION

NAGA, P.C.;

Before the Commission is a Fact-Finding Report dated 12 July 2022 (FFR) and a Supplemental Fact-Finding Report dated 13 February 2023 (Supplemental FFR) from the Complaints and Investigation Division (CID) of the National Privacy Commission (NPC).

The CID, pursuant to its power to conduct *sua sponte* investigations under Rule X of NPC Circular 2021-01 or the 2021 Rules of Procedure of the National Privacy Commission, filed an FFR against BDO Unibank, Inc. (BDO). The FFR stems from a *sua sponte* investigation of a possible personal data breach that resulted in unauthorized fund transfers that affected individuals holding bank accounts with BDO. Further, the FFR alleged that BDO committed violations of Sections 26 and 30 of the Republic Act No. 10173 or the Data Privacy Act of 2012 (DPA).

Facts

The CID submitted to the Commission En Banc an Initial Report tagged as QRSC 21-130 dated 13 December 2021, concerning the alleged hacked BDO accounts and unauthorized fund transfers to the

multiple Unionbank of the Philippines (Unionbank) accounts of a certain “MDN”¹

On 13 December 2021, the CID issued a Notice to Explain (NTE) to BDO concerning the alleged hacking into several BDO accounts which caused unauthorized transfer of significant funds to a certain “MDN”, owner of multiple Unionbank accounts.² Further, CID requested additional information on the following matters:

1. Nature and chronology of event[s] leading to the security incident and/or unauthorized transactions;
2. The extent of the compromise on the personal data of the account holders;
3. Explain how BDO Unibank’s 10-year-old web service system, which is due for replacement, has been affected by the alleged personal data breach incidents; and
4. What are the remedial measures being implemented in response to this incident.³

Lastly, in the same NTE, CID reminded BDO of NPC Circular No. 16-03 (Personal Data Breach Management), that a Breach Notification Report must be filed within seventy-two (72) hours upon knowledge of a data breach.⁴

On 13 December 2021, the CID likewise sent an NTE to Unionbank in relation to the same matter.⁵

On 16 December 2021, BDO submitted its response to the NTE issued by CID.⁶ In their response, they alleged that:

1. Nature and chronology of events leading to the security incident and/or unauthorized transactions

On or about December 6, 2021, the Bank’s Fraud Management Team detected irregular activities after receiving reports that a

¹ Complaints and Investigation Division, In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Initial Report dated 13 December 2021.

² Complaints and Investigation Division, Notice to Explain dated 13 December 2021 to BDO Unibank, Inc.

³ *Id.*

⁴ *Id.*

⁵ Complaints and Investigation Division, Notice to Explain dated 13 December 2021 to Union Bank of the Philippines.

⁶ BDO Unibank, Inc., Letter of Explanation to the NTE dated 16 December 2021.

number of clients' accounts may have been subjected to a new and sophisticated fraud technique. This fraud technique was initiated through phishing of clients, which led to unauthorized transactions using BDO Unibank online banking platform.

On December 11, 2021, the Bank was able to confirm the advanced fraud technique and immediately implemented security controls to contain the fraud attempts to clients' accounts.

On December 12, 2021, there were zero reports of incidents in connection with the foregoing activities.

2. The extent of the compromise on the personal data of the account holders

No personal data in the possession of BDO was compromised based on the following considerations:

- ☐ User IDs and passwords were inputted by the fraudster and were not taken from the BDO system. Passwords are stored using a one-way hash, and the Bank cannot decrypt what the accountholders have assigned as passwords to their respective accounts.
- ☐ The fraudster used the web service, and not the mobile banking application. As such, the fraudster did not have access to sensitive personal information or any other information that may be used to enable identity fraud.
- ☐ Web services used by the fraudster did not return personal information.

3. Explain how BDO Unibank's 10-year old web service system, which is due for replacement, has been affected by the alleged personal data breach incidents

A patch was applied to address the vulnerability on the legacy web service which is now in the process of being replaced. The replacement is currently in beta test, targeted for public launch in January 2022. Notwithstanding the foregoing, there was no personal data breach originating from the Bank.

4. What are the remedial measures being implemented in response to this incident

At the outset of detection of the irregular activities, the Bank immediately applied a patch to address the vulnerability on this legacy web-service application which is presently in the process of being replaced. The Bank's quick-action response included, among others, the forced expiration of existing passwords of online banking users in order for them to update their

passwords. The Bank addressed various communications on different media in order to clarify the incident.⁷

On 17 December 2021, Unionbank sent its response to the NTE dated 15 December 2021, stating that “there is no Union Bank account holder named MDN. The beneficiary accounts of the funds involved in the alleged hacking are legitimate accounts which were subjected to Union Bank’s know-your-customer mechanism. The use of the name MDN is a misuse of the Instapay beneficiary name.”⁸ Moreover, Unionbank stated that upon their investigation, it identified less than ten (10) accounts involved in the alleged hacking.⁹ Unionbank also alleged that “the account and funds involved were already frozen and is currently coordinating with BDO and Bangko Sentral ng Pilipinas (BSP) on the matter.”¹⁰

Also on 17 December 2021, CID issued an Order requiring BDO to furnish the Commission within ten (10) days from receipt with the following information and/or documents:

1. Documentation pertaining to the following contents of the Letter-Reply of BDO dated 16 December 2021:
 - a. How did the BDO Fraud Management Team positively identified the fraud techniques employed by the supposed scammer/threat actor as phishing activities?
 - b. What security controls were implemented to contain the fraud attempts?
 - c. How was it determined that the fraudster used the banking web service and not the mobile banking application?
 - d. The remedial measures implemented in response to this incident.
2. All Incident Response Reports regarding the attack, which must include:
 - a. The identified information security incidents that have been assessed and have been addressed;
 - b. The procedures which were implemented or executed during the monitoring, detecting, analyzing, and reporting of the relevant information security events;

⁷ BDO Unibank, Inc., Letter of Explanation to the NTE dated 16 December 2021.

⁸ Union Bank of the Philippines, Letter of Explanation dated 15 December 2021

⁹ *Id.*

¹⁰ *Id.*

- c. Documents and/or communications involving, in connection with, or relevant to the security breach when the Incident Response procedures were implemented.
3. All Change Management reports that documented the safeguards that BDO implemented as part of its incident response.
4. All Risk Management reports in relation to the security incident, including the standard operating procedures in handling risks, and reporting and documentation procedures in relation thereto.
5. Vulnerability Assessment Reports of BDO's website and e-mail servers, specifically, those involving the internet domain of "https://online.bdo.com.ph/" and the subdomains thereof.
6. A copy of BDO's reports submitted to the Bangko Sentral ng Pilipinas in relation to this incident.
7. Information on the relevance and significance of the mentioned 10 year-old web service system in the previous submission to this incident.¹¹

On 20 December 2021, the CID submitted a Supplemental Initial Report, recommending a *sua sponte* investigation under Rule X of the NPC Circular No. 2021-01 (2021 NPC Rules of Procedure) to further investigate the circumstances surrounding the possible personal data breach.¹²

On 22 December 2021, the CID issued an Order to Appear for Clarificatory Conference to BDO¹³ and Unionbank,¹⁴ respectively, requiring them to appear before the Commission on 04 January 2022 via Microsoft (MS) Teams.¹⁵

¹¹ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., Order dated 17 December 2021.

¹² Complaints and Investigation Division, In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Supplemental Report dated 20 December 2021.

¹³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Order To Appear for Clarificatory Conference dated 22 December 2021.

¹⁴ In re: The Matter of Hacking of Certain BDO Unibank, Inc. Accounts, NPC Case SS 21-023, Order To Appear for Clarificatory Conference dated 22 December 2021.

¹⁵ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Order To Appear for Clarificatory Conference dated 22 December 2021.

On 31 December 2021, BDO submitted its compliance to the Order dated 17 December 2021.¹⁶ In their Compliance to the said Order, BDO provided a timeline on the events that led to the identification of the techniques employed by the alleged threat actor as well as the actions taken by them to address the same:

- On 03 December 2021, upon reviewing of disputed Online Banking fund transfers which were reported by accountholders between 01 December 2021 and 03 December 2021, the Bank's Consumer Banking Group (CBG) - Fraud noticed that on about seventy (70) cases reported, there was a common mobile device name.
- On 06 December 2021, upon investigation of the transaction logs and receipt of additional disputes from accountholders, there appeared to be a pattern wherein, aside from the use of the User ID and password of the accountholders, the authentication used for the Online Banking log-in on the disputed transactions was a One-time PIN (OTP) from the OTP generator feature of the Mobile Banking (MB) Application (App).
- On 08 December 2021, the MB App OTP Generator option was disabled by the Bank for Online Banking. In addition, CBG-Fraud continued to monitor the situation, and noticed that dispute cases have stopped.
- On 09 December 2021, new disputes were reported, and there appeared to be a new pattern from these transactions, wherein the threat actor used the MB web services in order to enroll a rogue device to the customer's online banking account, and allowed said threat actor, together with the phished User ID and password, to access the customer's online banking account.
- On the same date, 09 December 2021, that this new pattern was discovered, BDO reduced the maximum limit for allowed enrolled device to only one (1) device per customer for online banking, from the previous allowance of up to five (5) devices per customer.
- On 10 December 2021, the Bank continued to monitor the situation, and saw an increase in alerts and clients responding to the SMS notification with "unauthorized transaction" that triggered further review of transactions. This review revealed a new pattern showing use of the same device ID but the authentication used this time was the customer's own phone touch/face ID.
- On 12 December 2021, the Bank introduced additional hashed keys in the system for authentication in order to protect the web services from another attack. In addition, the Bank also force-expired passwords to ensure that customers update their

¹⁶ BDO Unibank, Inc., Response to the Order dated (17 December 2021) dated 31 December 2021.

passwords in order to protect their accounts.¹⁷

Moreover, BDO described the three (3) techniques that were used by the alleged fraudster namely: 1) Mobile Banking (MB) One Time Password (OTP) Generator Compromise; 2) Rogue Device Registration; and 3) Touch Identification (ID) Authentication Bypass.¹⁸

In relation to BDO's Incident Response Reports regarding the attack, BDO stated:

- a. The identified information security incidents that have been assessed and have been addressed;
Please refer to the Bank's replies to items 1.c and 1.d.
- b. The procedures which were implemented or executed during the monitoring, detecting, analyzing, and reporting of the relevant information security events;
 - ☐ BDO's Security Operations Center (SOC) follows the Incident and Request Handling Guidelines -- a standard IT incident management process which covers security incidents, among others.
 - ☐ The template used is the general incident report template for all IT issues.
 - ☐ In addition to the abovementioned process, the incidents are now escalated to the Information and Cyber Security Office (ICSO) – Incident Management (IM) team for enterprise incident and crisis management.
- c. Documents and/or communications involving, in connection with, or relevant to the security breach when the Incident Response procedures were implemented.

Not applicable as there was no security breach that occurred.¹⁹

Further, BDO alleged that the following system changes were implemented in accordance with their standard application change control process, to wit:

- Force-expired passwords
- Online Banking reconfigured to reject MB OTP Authenticator

¹⁷ BDO Unibank, Inc., Response to the Order dated (17 December 2021) dated 31 December 2021.

¹⁸ *Id.*, at p. 3.

¹⁹ *Id.*

- Maximum allowed device was reduced from 5 to 1 device per customer
- Touch ID login web service enhanced to check for a secret hash value, on top of the IMEI value supplied.

Please note that no separate report is necessary to address this incident.²⁰

As to BDO's Vulnerability Assessment Reports, BDO alleged that the "Mobile Banking system went full penetration testing for the current release, v5.9."²¹ Further, BDO declared that the rating from their independent reviewer, Cybertint, indicated that "the overall security of the system is High."²² Lastly, BDO claimed that the "Internet domain/e-mail servers were not affected by this incident."²³

Regarding BDO's reports submitted to BSP concerning the incident, it stated that:

Kindly note that based on BSP Memorandum No. M-2015-040, we elevated this request to the BSP and the guidance we obtained is that matters pertaining to BSP examination, including reports submitted to the BSP in connection with their regular or special examination of BSP-Supervised Financial Institutions, are confidential and cannot be disclosed. Please be assured, however, that the information provided by BDO to this Honorable Office in connection with this matter is consistent with the Bank's report to the BSP.²⁴

On 03 January 2022, the CID sent a letter to the National Bureau of Investigation (NBI) dated 31 December 2021, requesting for assistance in providing further information that the bureau may have concerning the alleged unauthorized processing of personal information related to the unauthorized access of BDO's system.²⁵

On 04 January 2022, the CID also sent a letter to the Bangko Sentral ng Pilipinas dated 21 December 2021, requesting for information to the following:

²⁰ BDO Unibank, Inc., Response to the Order dated (17 December 2021) dated 31 December 2021.

²¹ *Id.*

²² *Id.*

²³ *Id.*

²⁴ BDO Unibank, Inc., Response to the Order dated (17 December 2021) dated 31 December 2021.

²⁵ Complaints and Investigation Division, Letter to the National Bureau of Investigation dated 31 December 2021.

1. The actions you have required from BDO in relation to the incident;
2. The findings of your investigation in relation to the incident;
3. A copy of the report/s submitted by BDO to your office;
4. Should there be a decision/resolution on the matter, may we also request for a copy of the same.²⁶

On 04 January 2022, the CID conducted a clarificatory conference with BDO and Unionbank.²⁷ Thereafter, the CID issued an Order (After the Clarificatory Conference on 04 January 2022 with Subpoena Duces Tecum) to BDO and Unionbank, respectively.²⁸ Lastly, on even date, CID sent an Order to Philippine Payment Management Inc./Instapay (PPMI), to provide information, submit documents and appear for clarificatory conference.²⁹

In the said Order, the CID required BDO to submit the following information and documents:

1. Position Paper outlining BDO's stand on the possible data breach;
2. Copy of the phishing kit mentioned during the clarificatory conference;
3. Log-in logs for user accounts involved in the fraud incident or investigated by BDO as part of the fraud incident;
4. Reports identifying the other fraudulent activities that have been detected by BDO's security service providers or internal security officers;
5. BDO policies on take-down procedures, as well as proof of implementation of take-down of fraudulent sites, including the phishing website involved in the fraud incident;
6. Copy of the phishing website involved in the fraud incident;
7. Reports of third-party service providers on the fraud incident;
8. Incident reports on the fraud incident, including reports from third-party security providers;

²⁶ Complaints and Investigation Division, Letter to the Bangko Sentral ng Pilipinas dated 31 December 2021.

²⁷ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, (After the Clarificatory Conference on 04 January 2022 with Subpoena Duces Tecum dated 04 June 2022 to BDO Unibank Inc.; In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, (After the Clarificatory Conference on 04 January 2022 with Subpoena Duces Tecum dated 04 June 2022 to Union Bank of the Philippines.

²⁸ *Id.*

²⁹ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Order (To provide information, submit documents and appear for clarificatory conference) dated 04 January 2022, to Instapay.

9. Penetration testing reports conducted by the BDO in relation to the matter, which should include the scope, period, and exemptions, if any;
10. BDO's operations manual or standard policy instructions detailing the procedure in case of breach in the bank's system;
11. Privacy impact assessment reports, risk assessment reports, and vulnerability assessment reports covering the period when the incident transpired, as well as the latest incident reports, if any;
12. Network diagram showing how the OTP machine and web server is connected to the system;
13. Copies of quitclaims and other documents required from account holders seeking reimbursement from funds lost due to the fraud incident.³⁰

For Unionbank, the following documents /information are required:

1. Unionbank's operations manual or standard policy instructions;
2. Official documents outlining Unionbank's policies on account opening, including digital account opening; and
3. Investigation report on the fraud incident, redacting specific details covered by the Bank Secrecy Law, as may be necessary.³¹

For Instapay, CID averred that the Order was issued under the power of this Commission to investigate the circumstances surrounding personal data breaches and require information on a matter of data privacy, and to compel any entity to abide by its orders in relation to security incidents and personal data breaches, since the unauthorized transfer of funds was made through the PPMI's Instapay channel.³² Moreover, the following documents are being required:

1. In general:
 - a. Requirements for the registration of users of Instapay;
 - b. Requirements for the registration of banks participating in Instapay;
 - c. Limitations, terms and conditions given to the users of Instapay;

³⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, (After the Clarificatory Conference on 04 January 2022 with Subpoena Duces Tecum dated 04 June 2022 to BDO Unibank Inc.

³¹ *Id.*

³² In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Order (To provide information, submit documents and appear for clarificatory conference) dated 04 January 2022, to Instapay.

- d. Security measures are available for the validation/confirmation of the identity of the users of Instapay, including the sender and the receiver of funds transferred through Instapay;
- e. When a bank account owner transfers funds from one bank to another bank through Instapay:
 - i. What are the requirements are needed to execute and complete a fund transfer, including the manner of authorization?
 - ii. What information are required from the sender-account user for the transfer of funds?
 - iii. How much time is allowed/required for the authentication of the details and approval/crediting of the transaction?
 - iv. What information are provided to the originating bank?
 - v. What information are provided to the recipient bank?
 - vi. What security measures are available for the validation/confirmation of the identity of the senders and recipients?
- f. Where does Instapay store personal information, it collects and processes?
- g. What existing personal, technical, and organizational security measures are in place to protect the personal data collected and processed by Instapay?

2. In relation to the incident:

- a. Participation of Instapay in the incident;
- b. Nature and chronology of the event leading to the security incident and/or unauthorized transactions;
- c. Investigation Report or the Results of the investigation, including:
 - i. The personal data affected/compromised;
 - ii. The number of accounts which are found to be part of the fraudulent scheme;
 - iii. The number of complaints received about the incident; and
- d. Upon knowledge of the incident, what remedial measures were taken to address the same and prevent/mitigate its recurrence?³³

On 18 January 2022, PPMI submitted their Compliance to the Order dated 04 January 2022 of CID with its attachments, Annex 1 “BSP Circular No. 980 – Adoption of National Retail Payment System Framework series of 2017”³⁴, Annex 2 – “BSP Circular No. 950 – Amendments to Part Eight or the Anti-Money Laundering

³³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Order (To provide information, submit documents and appear for clarificatory conference) dated 04 January 2022, to Instapay.

³⁴ Philippine Payment Management, Inc. (PPMI), Reply to the Order (dated 04 January 2022) dated 18 January 2022, See: Annex 1 “BSP Circular No. 980 – Adoption of National Retail Payment System Framework series of 2017”.

Regulations of MORB”³⁵, and Annex 3 – “InstaPay Operations Manual V2.1 (2021-01-13)”^{36,37} Moreover, in PPMI’s Compliance, they stated that “in its mandate as a Payment System Management Body accredited as such by the BSP deals directly with its members which consist of BSP supervised financial institutions or BSFIs. These are the universal/commercial banks, thrift banks, rural banks and electronic money issuers (EMIs).”³⁸

On 22 January 2022, the BDO sent its response to the Order of CID dated 04 January 2022.³⁹ In their response, BDO claimed that there was no personal data breach originating from the bank.⁴⁰ Further, in compliance with the CID’s requirement to submit documents, BDO stated that:

In compliance with said Order, please find herewith the following documents:

1. Position Paper outlining BDO’s stand on the possible personal data breach (item 1)
2. Summary Report and Certifications on the following:
 - a. Penetration testing reports conducted by BDO in relation to the matter, which should include the scope, period, and exemptions, if any (item 9)
 - b. Privacy impact assessment reports, risk assessment reports, and vulnerability assessment reports covering the period when the incident transpired, as well as the latest incident reports, if any (item 11)

However, with regard to the other documents being required by the CID in their Order dated 04 January 2022, BDO qualified that:

As regards the documentation enumerated below, the Bank respectfully submits that these items have been submitted pursuant to a Report on Examination, and are now subject of the jurisdiction of the Bangko Sentral ng Pilipinas (BSP). Considering that said documents are now part of the Report on Examination, the disclosure to outside parties requires prior BSP approval for the following documents:

³⁵ *Id.*, See: Annex 2 – “BSP Circular No. 950 – Amendments to Part Eight of the Anti-Money Laundering Regulations of MORB”

³⁶ *Id.*, See: Annex 3 – “InstaPay Operations Manual V2.1 (2021-01-13)”

³⁷ *Id.*

³⁸ *Id.*

³⁹ BDO Unibank, Inc., Response to the Order (dated 04 January 2022) dated 22 January 2022.

⁴⁰ *Id.*, at p. 1.

1. Reports identifying the other fraudulent activities that have been detected by BDO's security service providers or internal security officers. (item 4)
2. BDO policies on take-down procedures, as well as proof of implementation of take-down of fraudulent sites, including the phishing website involved in the fraud incident (item 5)
3. Reports of third-party service providers on the fraud incident (item 7)
4. Incident reports on the fraud incident, including reports from third-party security providers (item 8)
5. BDO's operations manual or standard policy instructions detailing the procedures in case of breach in the bank's system (item 10)
6. Network diagram showing how the OTP machine and web server is connected to the system (item 12)

With regard to the documents enumerated below, the Bank respectfully submits that inquiry and disclosure of said information and/or documents are proscribed under Republic Act No. 1405, as amended, otherwise known as the Bank Secrecy Law, particularly:

1. Log-in logs for user accounts involved in the fraud incident or investigated by BDO as part of the fraud incident (item 3)
2. Copies of quitclaims and other documents required from account holders seeking reimbursement from funds lost due to the fraud incident (item 13) – While the Bank is precluded by the Bank Secrecy Law to provide the executed quitclaims of the clients as they contain the account holder's account information, the Bank is able and willing to provide the template quitclaim for your consideration.

For the Copy of the phishing kit mentioned during the clarificatory conference (item 2), the Bank is able and willing to provide the same to this Honorable Commission, with a request for this Honorable Commission to keep the document confidential. For this purpose, we have provided our standard Non-Disclosure Agreement for your consideration.

As regards the Copy of the phishing website involved in the fraud incident (item 6), the Bank respectfully submits that it does not track phishing websites as there are far too numerous and are immediately taken down upon detection.⁴¹

On 22 January 2022, the CID issued a letter to NBI requesting further information with regard to the participation of web developers and

⁴¹ BDO Unibank, Inc., Response to the Order (dated 04 January 2022) dated 22 January 2022, at p. 1-2, See: Attachments.

downloaders individuals, the operation of scam pages, and other necessary information.⁴²

On 03 February 2022, the CID issued an Order to BDO, to show cause why it should not be held in contempt for its failure to provide the documents required by the Commission in the Order dated 04 January 2022.⁴³

On 09 February 2022, BDO submitted a letter requesting five (5) days extension to comply with the Order since it still needs to clarify how it can comply without violating any of its obligations under the law.⁴⁴

On 14 February 2022, BDO submitted a letter in response to the Order to show cause, stating that some of the documents were already within the jurisdiction of the BSP as the primary regulator of the banks, and BSP confirmed that these are confidential.⁴⁵ It also stated that phishing kits are considered trade secrets.⁴⁶

On 16 February 2022, CID issued a letter to SEC, requesting SEC documents related to BDO such as a General Information Sheet, Certificate of Registration, Articles of Incorporation, and other related filings.⁴⁷

On 15 March 2022, CID issued a Technical Report stating that the Mobile Application Penetration Test is not supported by additional information that will allow the Technical Team to validate and confirm the results of the test, Engagement Completion Form does not identify the results of the Privacy Impact Assessment and measures taken by BDO to remedy security issues detected, if any, and The Mobile Banking PCI-ASV Vulnerability Reports do not contain information that will allow the Technical Team to confirm and validate the results.⁴⁸ CID stated that "the penetration test aims to

⁴² Complaints and Investigation Division, Letter to the National Bureau of Investigation dated 31 December 2021.

⁴³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Order (to Show Cause) dated 03 February 2022.

⁴⁴ BDO Unibank, Inc., Request for an additional period to respond dated 09 February 2022.

⁴⁵ BDO Unibank, Inc., Response to Order (03 February 2022) dated 14 February 2022.

⁴⁶ *Id.*

⁴⁷ Complaints and Investigation Division, Letter to the Securities and Exchange Commission dated 16 February 2022.

⁴⁸ Complaints and Investigation Division, Technical Report to CID 22-0020 dated 15 March 2022.

test BDO's mobile application for vulnerabilities and deliver actionable evidence and guidance to assist with mitigations."⁴⁹

The CID furnished the Commission En Banc of its Fact-Finding Report dated 12 July 2022 concerning the *sua sponte* investigation instituted against BDO.⁵⁰ The CID's *sua sponte* investigation involved BDO, Unionbank, and Philippine Payments Management Inc., operator of InstaPay (InstaPay).⁵¹

Nevertheless, although the CID investigated three parties, it ultimately asserted that only BDO was liable for violations of the DPA. Thus, the CID made the following recommendations:

In light of the foregoing, it is recommended that the Commission:

1. FINDS BDO liable for violation of Section 26 of the DPA for providing access to personal information and sensitive personal information due to negligence;
2. FINDS BDO liable for violation of Section 30 of the DPA for concealment of security breaches involving sensitive personal information;
3. RECOMMEND to the Department of Justice for criminal prosecution for violation of Section 26 and Section 30 of the DPA against BDO's board of directors, including TTS, JAJ, GTB, CAB, JFB, JMC, VSP, DIR, NVT, JNT, and GCT; and
4. FILE a petition for indirect contempt against BDO for its refusal to obey the Commission's orders.⁵²

Meanwhile, the CID recommend neither PPMI (InstaPay) or Unionbank liable for privacy violations.

With regard to InstaPay, the CID claimed that "[i]n accordance with BSP Circular No. 980, series of 2017, only the account numbers are collected when transferring funds from one bank to another. No

⁴⁹ Complaints and Investigation Division, Technical Report to CID 22-0020 dated 15 March 2022.

⁵⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

⁵¹ *Id.*

⁵² *Id.*, at p. 41.

other personal information is required.”⁵³ The CID also stated that “[InstaPay] does not appear to have direct involvement in the fraud incident. Instapay appears to have been used as the fund transfer mechanism to transfer funds from BDO to other bank accounts because Instapay allows for the instantaneous transfer of funds.”⁵⁴

Thus, the CID contends that “[o]ther than utilizing Instapay for fund transfer, however, the investigation did not uncover any evidence showing how Instapay or PPMI [Philippine Payments Management, Inc. (PPMI)] could have been involved in the fraudulent fund transfer. In other words, Instapay simply happened to be the most convenient method for transferring funds.”⁵⁵

Meanwhile, for Unionbank, the CID explained that for domestic account-to-account electronic payments, it does not appear to include the processing of any additional personal information apart from the account number.⁵⁶ The CID further emphasized that:

...Union Bank is not the only bank where funds involved in the BDO fraud incident have been transferred. Union Bank only came under scrutiny because it appears that many of the fraudulent transactions resulted in fund transfers to Union Bank accounts. Apart from being the bank where several recipient accounts were found, however, Union Bank appears to have no other involvement in the matter. The mere fact that funds from the fraud incident were transferred to Union Bank does not automatically make Union Bank a party to the fraud incident, either as principal, accomplice, or accessory.⁵⁷

In contrast, the CID found that BDO failed to notify the Commission and affected data subjects of the breach in accordance with NPC Circular No. 16-03.⁵⁸ The CID argued that the failure to notify made BDO liable for Section 30 of the DPA (Concealment of Security Breaches Involving Sensitive Personal Information).⁵⁹

⁵³ *Id.*, at p. 6.

⁵⁴ *Id.*

⁵⁵ *Id.*

⁵⁶ Fact-Finding Report dated 12 July 2022 of the Complaints and Investigation Division (CID), at p. 7.

⁵⁷ *Id.*

⁵⁸ *Id.*, at p. 27.

⁵⁹ *Id.*, at pp. 27-28.

Next, the CID also asserted that BDO is liable for Section 26 of the DPA (Accessing Personal Information and Sensitive Personal Information Due to Negligence) since it failed to exercise the required degree of diligence in the conduct of its affairs.⁶⁰

Thereafter, CID argued that BDO's Board of Directors are liable for the violations of the DPA, citing Sec. 34 of the same act, to wit:

Section 34 of the DPA states that liability under the DPA when the offender is a corporation "shall be imposed upon the responsible officers, as the case may be, who participated in, or by their gross negligence, allowed the commission of the crime,"⁶¹

Particularly, CID stated that the Board of Directors must have been aware of the security incident, to wit:

Likewise, BDO's board of directors must have been aware of the incident in question as its President, Nestor Tan, made an announcement regarding the incident which was posted in the Philippine Daily Inquirer on 12 December 2021. BDO also released an official statement on 14 December 2021. In spite of its knowledge of the security incident, BDO's board of directors did not notify the Commission of the personal data breach.⁶²

For this reason, CID believes that BDO's Board of Directors must be liable for the concealment of security breach and for providing access to personal information through negligence.

Lastly, the CID argued that BDO should be cited in contempt since it allegedly refused to provide the information required by the CID.⁶³ Thus, the CID recommended that a petition for indirect contempt be filed against BDO.⁶⁴

In turn, BDO submitted its Supplement to the Position Paper dated 22 January 2022, dated 19 August 2022, stating that:

⁶⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022, at pp. 29- 32.

⁶¹*Id.*, at p. 35.

⁶²*Id.*, at p. 35.

⁶³ *Id.*, at pp. 35-40.

⁶⁴ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022, at p. 41.

The Bank, however, would like to sincerely acknowledge its failure to promptly notify this Honorable Commission of the said unauthorized fund transfers, and the events leading thereto. Such failure was due solely to the fact that the Bank, immediately upon the occurrence of the incident, convened its Cybersecurity Incident Response and Crisis Management teams and strongly focused, with utmost sense of urgency, on identifying and launching the counter-attacks against the threat actors to prevent further exposure, negative impact, or damage to the affected online banking clients and to the Bank, as well as prevent the recurrence of the incident. Thereafter, the Bank launched various counter-attacks against the threat actors, and instituted safeguards to prevent the personal data of its clients from being compromised.⁶⁵

In the same submission, BDO further stated that:

Once again, The Bank sincerely acknowledges its failure to notify this Honorable Commission of the incident relating to the unauthorized fund transfers of its online banking clients. The Bank begs the indulgence of this Honorable Commission and undertakes to immediately involve, work with, and closely cooperate with this Honorable Commission should a similar incident involving personal data in the custody of the Bank occur in the future, whether or not the same involves a personal security breach, a security incident, or otherwise. ⁶⁶

BDO filed its Manifestation dated 26 August 2022, claiming that “the phishing was directed by the threat actors against the account holders, it was impossible for the Bank to know whether the fact of phishing occurred, or who were victimized thereby, It is for this reason that the Bank was unable to notify the affected clients of the unauthorized fund transfers.”⁶⁷ BDO attached Annexes 1-50 showing the fifty (50) case logs documenting calls from its affected clients.⁶⁸

In support of its FFR, CID submitted its Supplemental Fact-Finding Report dated 13 February 2023.⁶⁹ In the said Supplemental Fact-Finding Report (Supplemental FFR), CID raised the same issues,

⁶⁵ Supplement to the Position Paper dated 22 January 2022 dated 19 August 2022 of BDO Unibank Inc., at p. 1.

⁶⁶ Supplement to the Position Paper dated 22 January 2022 dated 19 August 2022 of BDO Unibank Inc., at p. 5.

⁶⁷ BDO Unibank, Inc., Manifestation dated 26 August 2022 of BDO Unibank Inc., at p. 1.

⁶⁸ Manifestation dated 26 August 2022 BDO Unibank, Inc., at p. 2.

⁶⁹ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Supplemental Fact-Finding Report dated 13 February 2023.

namely: “whether or not BDO violated Section 26 of the Data Privacy Act (“DPA”) by providing access to personal information and sensitive personal information through negligence and Section 30 of the DPA by concealing a security breach.”⁷⁰

To summarize, CID detailed:

In summary, a careful review of the Supplement to the Position Paper dated 22 January 2022, dated 19 August 2022, and the Manifestation dated 26 August 2022 shows (i) that the matters raised were irrelevant because the NBI’s entrapment, the voluntary return to clients of the funds that were illegally transferred from their accounts, and news reports about the NBI and L neither prove nor disprove the existence of a privacy violation or violations of Sections 26 and 30 of the DPA, (ii) that fund transfers could only have been affected with the use of data subject’s personal information, (iii) that the breach of BDO’s OTP generator, rogue device registration, and touch ID authentication bypass show that BDO’s security measures are insufficient to protect the data subjects’ personal information, (iv) that BDO’s manifestation does not negate the requirement for BDO to notify the Commission under Section 20 (f) since BDO admitted in a letter dated 16 December 2021 that it was aware of fraud as early as 06 December 2021, and (v) that the case logs only show that several of BDO’s clients could not have been phished because they did not receive phishing calls, SMS, or emails.⁷¹

Thus, CID made its recommendation:

In light of the foregoing and after a careful review of the Supplement to the Position Paper dated 22 January 2022, dated 19 August 2022, and the Manifestation dated 26 August 2022, the CID affirms its Amended Fact-Finding Report dated 12 July 2022.⁷²

On 30 June 2023, the Commission issued an Order to BDO:

WHEREFORE, premises considered, BDO Unibank, Inc. (BDO) and its responsible officers are hereby **ORDERED** to file its **COMMENT** on the Fact-Finding Report dated 12 July 2022, and Supplemental Fact-Finding Report dated 13 February 2023 of

⁷⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Supplemental Fact-Finding Report dated 13 February 2023, at p. 2.

⁷¹ *Id.*, at p. 5.

⁷² *Id.*, at p. 5.

the Complaints and Investigation Division (CID) **within fifteen (15) days** from receipt of this Order.⁷³

On 29 September 2023, BDO through counsel Divina Law, submitted a request for an extension of time within which to respond to the Order of the Commission dated 30 June 2023 due to “the heavy pressure of other equally important and urgent professional work, consisting of meetings, tight deadlines, and other court hearings.”⁷⁴

On 13 October 2023, BDO filed an Omnibus Motion with the Court of Appeals (CA) praying for the nullification of the issued Order dated 30 June 2023 by the NPC and enjoining it from acting on the Fact-Finding Reports and further proceedings in NPC SS 21-023, *to wit*:

WHEREFORE, premises considered, it is respectfully prayed that the Honorable Court **NULLIFY** respondent NPC’s Order dated 30 June 2023 and **ENJOIN** respondent NPC from acting on the Fact-Finding Reports and further proceeding in NPC SS 21-023.⁷⁵

In said Motion, BDO contended that the logical consequence of the NPC’s 30 June 2023 Order to Comment is to compel it to submit the subject documents, which the CA already enjoined.⁷⁶ More so, BDO allegedly “cannot comment nor meaningfully participate in NPC SS 21-023 without submitting the subject documents,” in violation of its right to due process.⁷⁷

On 23 October 2023, BDO submitted a Letter⁷⁸ with the NPC, praying for the deferment or holding in abeyance the proceedings in NPC SS 21-023:

Considering the prayer stated therein, we respectfully pray, in the interest of prudence and judicial deference, that the Honorable Commission defer/hold in abeyance the proceedings in NPC SS 21-023, including the directive of this Honorable Commission for BDO to comment, pending the

⁷³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Order dated 30 June 2023.

⁷⁴ BDO Unibank Inc., Request for Extension of Time dated 29 September 2023.

⁷⁵ *BDO Unibank, Inc. vs. National Privacy Commission, C.A.-G.R. SP NO. 172458*, Omnibus Motion dated 13 October 2023.

⁷⁶ *Id.*

⁷⁷ *Id.*

⁷⁸ BDO Unibank, Inc., Letter (Request to Defer/Hold in Abeyance), dated 23 October 2023.

resolution of the aforesaid Omnibus Motion by the Court of Appeal.⁷⁹

However, on 12 December 2023, the Commission addressed BDO's Letter dated 23 October 2023, to wit:

WHEREFORE, premises considered, the Commission resolves to **DENY** the Request to Defer or Hold in Abeyance the Proceedings of BDO Unibank, Inc. for NPC SS 21-023. The Commission hereby **DIRECTS** BDO Unibank, Inc. to file its **COMMENT** to the Fact-Finding Report dated 12 July 2022, and the Supplemental Fact-Finding Report dated 13 February 2023 of the Complaints and Investigation Division **within a non-extendible period of five (5) days** from receipt of this Order.⁸⁰

On 06 March 2024, BDO submitted its Comment *Ad Cautelam*.⁸¹ BDO stated that the Commission's application of the plain meaning rule on the decision of the CA is misplaced since the instant case is anchored on the Subject Documents.⁸² BDO stated that the Subject Documents are necessary to refute the finding of the CID, as admitted by CID.⁸³ Moreover, BDO stated that the CID's findings on the FFR were hinged on the non-submission of the Subject Document.⁸⁴ Lastly, BDO prayed that the instant case be dismissed.⁸⁵

On 10 May 2024, BDO filed its Motion to Resolve *Ad Cautelam* praying that the Commission resolve the instant case and to render its Decision.⁸⁶

Moreover, in the same Motion, BDO submitted the following documents: Annex A – Series – Reports identifying other fraudulent activities that have been detected by BDO's security officers; Annex B – Series – BDO's Service Agreement with its anti-phishing vendor reflecting its policies on take-down procedures, privacy impact assessment report, Annex C – Series - Proof of implementation of take-down of fraudulent sites, report of third-party security providers (RSA) on the fraud incident, and incident reports on the

⁷⁹ BDO Unibank, Inc., Letter (Request to Defer/Hold in Abeyance), dated 23 October 2023.

⁸⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Order dated 12 December 2023.

⁸¹ BDO Unibank, Inc., Comment *Ad Cautelam* dated 06 March 2024.

⁸² *Id.*, at p. 2.

⁸³ *Id.*, at p. 2.

⁸⁴ *Id.*, at p. 3.

⁸⁵ *Id.*, at p. 12.

⁸⁶ BDO Unibank, Inc., Motion to Resolve *Ad Cautelam* dated 10 May 2024.

fraud incident; Annex D – BDO’s Data Breach Response Policy/Operation Manual; Annex E – Mobile Banking Architecture Diagram showing how the OTP Machine and the web server are connected to the system; Annex F – Series – Dispute Forms with Quitclaims signed by account holders (partial); Annex D – Log-in logs.⁸⁷

Issue

- I. Whether BDO Unibank Inc. is liable under Section 26 (Accessing Personal Information and Sensitive Personal Information Due to Negligence) of the DPA.
- II. Whether BDO Unibank Inc. is liable for Section 30 (Concealment of Security Breaches Involving Sensitive Personal Information) of the DPA.

Discussion

Under the DPA, the NPC has the obligation to ensure a personal information controller’s compliance with the law and institute investigations when necessary.⁸⁸

Further, the NPC’s mandate is supported by the 2021 NPC Rules of Procedure which allows the procedure for *sua sponte* investigations of circumstances surrounding possible privacy violations or personal data breaches.⁸⁹

The NPC’s CID is the division tasked to, among others, “[institute] investigations regarding violations of the Act, these Rules, and other issuances of the Commission, including violations of the rights of data subjects and other matters affecting personal data.”⁹⁰

An FFR is submitted to the Commission En Banc “for its perusal to determine whether violations of the Data Privacy Act of 2012 (DPA) were committed. Considering that the FFR contains all the findings of

⁸⁷ BDO Unibank, Inc., Motion to Resolve Ad Cautelam dated 10 May 2024.

⁸⁸ See Data Privacy Act of 2012, , chapter II, § 7.

⁸⁹ NPC Circular No. 2021-01, rule X, §§ 5-6.

⁹⁰ National Privacy Commission, Implementing Rules and Regulations of the Data Privacy Act of 2012, rule III, § (e)(1) (2016) (IRR of the DPA).

the investigating division of the NPC, such document is the complaint initiating the administrative proceedings in cases of *sua sponte* investigation.”⁹¹ Thus, the FFR of the CID serves as the complaint in the *sua sponte* investigation.⁹²

By filing an FFR, the NPC, through the CID, initiated on its own accord a complaint against BDO. In effect, the CID serves as the nominal complainant in the proceedings against the respondent. Meanwhile, the NPC’s Commission En Banc acts as a collegial body to adjudicate the case.⁹³ It shall review the evidence presented, including the FFR and supporting documents.⁹⁴

Guided by such pronouncements and after carefully considering the claims, and evidence presented by both parties, the Commission resolves to dismiss the complaint for lack of substantial evidence to warrant a finding of a violation of the DPA.

I. BDO is not liable for violating Section 26 (Accessing Personal Information and Sensitive Personal Information Due to Negligence) of the DPA.

In the CID’s FFR, it alleged that BDO is liable for Accessing Personal Information and Sensitive Personal Information Due to Negligence under Section 26 of the DPA.⁹⁵

Section 26 of the DPA provides:

SEC. 26. *Accessing Personal Information and Sensitive Personal Information Due to Negligence.* – (a) Accessing personal information due to negligence shall be penalized by imprisonment ranging from one (1) year to three (3) years and a

⁹¹ *In re: FCash Global Lending Inc., Operating FastCash Online Lending Application*, NPC 19-909, Resolution dated 28 April 2022., at pp. 3-4.

⁹² NPC Circular No. 2021-01, rule X, §§ 3-5. *See In re: FCash Global Lending Inc., Operating FastCash Online Lending Application*, NPC 19-909, Resolution dated 28 April 2022.

⁹³ *See* Data Privacy Act of 2012, , chapter II, § 7(b).

⁹⁴ NPC Circular No. 2021-01, rule VIII, § 1.

⁹⁵ *In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc.*, NPC SS 21-023, Fact Finding Report dated 12 July 2022.

fine of not less than Five hundred thousand pesos (Php500,000.00) but not more than Two million pesos (Php2,000,000.00) shall be imposed on persons who, due to negligence, provided access to personal information without being authorized under this Act or any existing law.

(b) Accessing sensitive personal information due to negligence shall be penalized by imprisonment ranging from three (3) years to six (6) years and a fine of not less than Five hundred thousand pesos (Php500,000.00) but not more than Four million pesos (Php4,000,000.00) shall be imposed on persons who, due to negligence, provided access to personal information without being authorized under this Act or any existing law.⁹⁶

To be held liable under Section 26, the following elements must be met:

1. There is personal information or sensitive personal information;
2. The personal or sensitive personal information was accessed;
3. The access was not authorized under the DPA or any existing law; and
4. The unauthorized access was due to the negligence of any person.⁹⁷

Section 3 (g) of the DPA defines personal information as:

Personal information refers to any information whether recorded in a material form or not, from which the identity of an individual is apparent or can be reasonably and directly ascertained by the entity holding the information, or when put together with other information would directly and certainly identify an individual.⁹⁸

Sensitive personal information is defined by Section 3(l) of the DPA as personal information:

⁹⁶ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter VIII, § 26 (2012).

⁹⁷ NPC 22-006 (*unreported*), Decision dated 19 January 2023, at p. 15.

⁹⁸ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter I, § 3(g) (2012).

- (1) About an individual's race, ethnic origin, marital status, age, color, and religious, philosophical or political affiliations;
- (2) About an individual's health, education, genetic or sexual life of a person, or to any proceeding for any offense committed or alleged to have been committed by such person, the disposal of such proceedings, or the sentence of any court in such proceedings;
- (3) Issued by government agencies peculiar to an individual which includes, but not limited to, social security numbers, previous or current health records, licenses or its denials, suspension or revocation, and tax returns; and
- (4) **Specifically established by an executive order or an act of Congress to be kept classified.**⁹⁹

In CID's FFR, it alleged that the data subjects' bank deposit details, including their bank account number and the amount in it, are confidential under the Bank Secrecy Law and thus considered sensitive personal information.¹⁰⁰ Moreover, the bank deposit details including the account number fall under "other information that may enable identity fraud" as specified in Section 20 (f) and the second paragraph of Section 11 (a), given that it pertains to the financial and economic situation of the data subject.¹⁰¹

The Commission agrees that the user IDs, passwords, IMEI, mobile number, and email address constitute information "from which the identity of an individual is apparent or can be reasonably and directly ascertained by the entity holding the information, or when put together with other information would directly and certainly identify an individual" and is thus considered personal information.¹⁰² Thus, the first element is present.

As to the second element, the CID asserted that the alleged threat actor was able to access at least 861 data subjects' user IDs, passwords, IMEI, bank account numbers, mobile numbers, email

⁹⁹ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter I, § 3(l) (2012).

¹⁰⁰ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹⁰¹ National Privacy Commission, Personal Data Breach Management, NPC Circular No. 16-03, rule V, § 11 (a).

¹⁰² In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

addresses, as well as financial information such as the data subject's accounts with the bank, including the amount of funds in each account.¹⁰³

In the case of IBP vs PBI,¹⁰⁴ Phishing has been defined as the fraudulent process of attempting to acquire private or confidential information by masquerading as a trustworthy entity in an electronic communication.¹⁰⁵ In BDO's Position Paper, it claimed that the "phished credentials used in effecting the unauthorized fund transfers were obtained by the threat actors not from the Bank's computer systems but from the account holders themselves (whether inadvertently or otherwise) through sophisticated phishing techniques.¹⁰⁶ Since BDO maintains that there was a phishing activity that led to the unauthorized fund transfers, the alleged threat actor was able to access the personal and sensitive personal information of the affected data subjects. Thus, the second element is likewise present.

The CID claims that BDO indeed provided access to the "attacker" and allowed the OTP generator to generate legitimate OTP, allowed access to rogue devices, allowed touch ID, and for failure to secure its system to prevent access.¹⁰⁷ However, BDO, in its Position Paper claims that:

The Bank respectfully submits that the phished credentials used in effecting the unauthorized fund transfers were obtained by the threat actors not from the Bank's computer systems but from the account holders themselves (whether inadvertently or otherwise) through sophisticated phishing techniques. The unauthorized fund transfers would not have been successful without said threat actors' access to the phished credentials.¹⁰⁸

Nevertheless, the Commission finds that the allegation of CID has no ground since it failed to substantiate its claim that BDO provided access to the "attacker". Thus, the third element is lacking.

¹⁰³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹⁰⁴ ISO/IEC 27032:2012 (en), §4 Terms and definitions

¹⁰⁵ *IBC vs. PBI, NPC CID No. 17-K-004.*

¹⁰⁶ BDO Unibank, Inc., Position Paper dated 22 January 2022.

¹⁰⁷ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹⁰⁸ BDO Unibank, Inc., Position Paper dated 22 January 2022.

The fourth element is also absent. CID alleged that BDO failed to exercise extraordinary diligence to protect its clients.¹⁰⁹ Based on CID's submissions, there is no concrete evidence to conclude that the access made by the attacker was due to the negligence of BDO. CID merely alleged that BDO failed to employ measures to protect its data subjects. The CID, to support their recommendations, relied heavily on the following: BDO's Position Paper¹¹⁰ and Supplemental Position Paper¹¹¹, and CID's Technical Report¹¹² and Supplemental Report.¹¹³

The Commission emphasizes that, in this case, CID has the burden to prove that BDO indeed failed to employ measures. It is axiomatic that under the Rules on Evidence a party who alleges a fact has the burden of proving it. A mere allegation is not evidence, and he who alleges has the burden of proving his allegation with the requisite quantum of evidence.¹¹⁴

For *sua sponte* investigation before the Commission to prosper, the burden of proof required is substantial evidence, or "that amount of relevant evidence that a reasonable mind might accept as adequate to support a conclusion."¹¹⁵ Additionally, in administrative proceedings like this case, complainants "carry the burden of proving their allegations with substantial evidence." As further explained by the Supreme Court in *De Jesus v. Guerrero III*:

In administrative proceedings, the quantum of proof necessary for a finding of guilt is substantial evidence, i.e., that amount of relevant evidence that a reasonable mind might accept as adequate to support a conclusion. Further, the complainant has the burden of proving by substantial evidence the allegations in his complaint. The basic rule is that mere allegation is not evidence and is not equivalent to proof. Charges based on mere suspicion and speculation likewise cannot be given credence. Hence, when the complainant relies on mere conjectures and suppositions, and fails to substantiate

¹⁰⁹ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹¹⁰ BDO Unibank, Inc., Position Paper dated 22 January 2022.

¹¹¹ Supplement to the Position Paper dated 22 January 2022 dated 19 August 2022 of BDO Unibank Inc., at p. 5.

¹¹² Complaints and Investigation Division, Technical Report to CID 22-0020 dated 15 March 2022.

¹¹³ Complaints and Investigation Division, In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., QRSC 21-130, Supplemental Report dated 20 December 2021.

¹¹⁴ *Spouses Ramos vs. Obispo and Far East Bank and Trust Company*, G.R. No. 193804, February 27, 2013.

¹¹⁵ *De Jesus v. Guerrero III*, G.R. No. 171491, 04 September 2009.

his allegations, the administrative complaint must be dismissed for lack of merit.¹¹⁶

Rule XII, Section 8 of NPC Circular No. 2021-01 or the 2021 Rules of Procedure, provides:

SECTION 8. Application of Rules of Court. – The Rules of Court shall apply in a suppletory character and whenever practicable and convenient.¹¹⁷

Applying Rule 131 of the 2019 Amendments to the Revised Rules on Evidence, it provides:

Section 1. Burden of proof and burden of evidence. - **Burden of proof is the duty of a party to present evidence on the facts in issue necessary to establish his or her claim or defense by the amount of evidence required by law.** Burden of proof never shifts.

Burden of evidence is the duty of a party to present evidence sufficient to establish or rebut a fact in issue to establish a prima facie case. Burden of evidence may shift from one party to the other in the course of the proceedings, depending on the exigencies of the case.¹¹⁸

In this case, since CID failed to establish the third and fourth elements of Section 26 with substantial evidence, it cannot be held for violation of Access Due to Negligence.

II. BDO is not liable for violating Section 30 (Concealment of Security Breach Involving Sensitive Personal Information) of the DPA.

In CID's FFR, it alleged that BDO is liable for Concealment of Security Breaches Involving Sensitive Personal Information under Section 30 of the DPA. It provides:

¹¹⁶ *De Jesus v. Guerrero III*, G.R. No. 171491, 04 September 2009.

¹¹⁷ Rule XII, Section 8 of NPC Circular No. 2021-01 or the 2021 Rules of Procedure

¹¹⁸ 2019 Amendment to the 1989 Revised Rules on Evidence, A.M. No. 19-08-15-SC, Rule 131, Section 1. Emphasis supplied

Section 30. Concealment of Security Breaches Involving Sensitive Personal Information. The penalty of imprisonment of one (1) year and six (6) months to five (5) years and a fine of not less than Five hundred thousand pesos (Php500,000.00) but not more than One million pesos (Php1,000,000.00) shall be imposed on persons who, after having knowledge of a security breach and of the obligation to notify the Commission pursuant to Section 20(f), intentionally or by omission conceals the fact of such security breach.¹¹⁹

The requisites of Concealment of Security Breaches Involving Sensitive Personal Information are:

1. A personal data breach occurred;
2. The breach is one that requires notification to the Commission; and
3. The person knowingly conceals the fact of such breach from the Commission.¹²⁰

Section 30 of the DPA penalizes concealment or failure to notify the Commission of a security breach. Moreover, the Commission stresses that to be penalized under Section 30, the concealed security breach must be one that falls under the mandatory breach notification requirement under Section 20 (f) of the DPA, which provides

Section 20. *Security of Personal information*

...

(f) The personal information controller shall promptly notify the Commission and affected data subjects when sensitive personal information or other information that may, under the circumstances, be used to enable identity fraud are reasonably believed to have been acquired by an unauthorized person, and the personal information controller or the Commission believes that such unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject. The notification shall at least describe the nature of the breach, the sensitive personal information possibly involved, and the measures taken by the entity to address the breach. Notification may be delayed only to the extent necessary to determine the

¹¹⁹ Data Privacy Act of 2021, Section 30.

¹²⁰ Data Privacy Act of 2021, Section 30.

scope of the breach, to prevent further disclosures, or to restore reasonable integrity to the information and communications system.¹²¹

Additionally, Section 11 of NPC Circular No. 16-03 provides the elements of mandatory breach notification:

Section 11. When notification is required. Notification shall be required upon knowledge of, or when there is reasonable belief by the personal information controller or personal information processor that a personal data breach requiring notification has occurred, under the following conditions:

- A. The personal data involves sensitive personal information or any other information that may be used to enable identity fraud.
- B. There is reason to believe that the information may have been acquired by an unauthorized person; and
- C. The personal information controller or the Commission believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject.¹²²

In CID's FFR, they claim that there was a personal data breach.¹²³ CID stated that:

BDO admitted that a threat actor was able to use various techniques to carry out unauthorized fund transfers from data subjects with BDO accounts. On 6 December 2021, the threat actor used the OTP issued by the OTP generator feature of BDO's mobile banking application. When this feature was disabled, the threat actor was able to enroll rogue devices in the victims' accounts. And when enrollment was limited to only one device per client, the threat actor was able to use biometrics to access client accounts.¹²⁴

However, in response to CID's allegations, BDO stated in their Comment *Ad Cautelam*:

¹²¹ Data Privacy Act of 2012, § 20 (f).

¹²² National Privacy Commission, Personal Data Breach Management, Circular No. 3, Series of 2016 [NPC Circ. No. 16-03], §11 (15 December 2016).

¹²³ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹²⁴ *Id.*

12. In the course of proceedings before the CID, BDO has repeatedly and consistently raised the defense of phishing. It has consistently argued that there was no data breach as would make it liable for violation of the Data Privacy Act because the process leading up to the unlawful access to the account holders' online banking accounts, which resulted in the unauthorized funds transfers, began with the employment of various phishing techniques against the account holders, which is not equivalent to a breach of BDO's security.

13. BDO's defense of phishing is anchored on the Subject Documents because these documents clearly refute the accusation that there were no sufficient organizational, physical, and technical security measures in place to protect the data subject's personal and sensitive personal information. As such, BDO would not be able to competently defend itself in the instant proceedings without submitting the Subject Documents.¹²⁵

CID in its FFR, stated that BDO has "concealed the four (4) security breaches from the Commission [NPC] in spite of BDO's duty to reveal this information under the DPA and Section 11 of NPC Circular No. 16-03. As a result, the Commission [NPC] was completely in the dark from 3-16 December 2021 and was able to find out about the security breach when it exercised its investigatory powers and decided to issue a Notice to Explain to BDO."¹²⁶

However, an examination of the records shows that the CID failed to sufficiently prove that there was indeed a concealment of personal data breach based on their allegations. The CID merely made presumptions without any proof that BDO has knowingly concealed a breach to the Commission. In this case, the CID, as the Nominal Complainant, has the burden of proof and must prove its allegations with substantial evidence.

To reiterate, in administrative proceedings, it is the complainant who carries the burden of proving their allegations with substantial evidence or such "relevant evidence that a reasonable mind might accept as adequate to support a conclusion."¹²⁷

¹²⁵ BDO Unibank, Inc., Comment Ad Cautelam dated 06 March 2024.

¹²⁶ In the Matter of Alleged Personal Data Breach of BDO Unibank, Inc., NPC SS 21-023, Fact Finding Report dated 12 July 2022.

¹²⁷ *Ferancullo v. Ferancullo*, 538 Phil. 501, 511 (2006).

Since the FFR is treated as a complaint in *sua sponte* investigations, CID as the party who alleges a fact, has the burden of proving it. The Supreme Court held that “it is basic in the rule of evidence that bare allegations, unsubstantiated by evidence, are not equivalent to proof. In short, mere allegations are not evidence.”¹²⁸ Thus, the CID will not be able to discharge its burden of proof with substantial evidence by mere allegations.

Hence, failure to prove the third element, BDO cannot be held liable for Section 30 of the DPA.

Based on the foregoing discussions, this Commission cannot find BDO liable for violation of Sections 26 and 30 of the DPA. There is a lack of substantial evidence to prove a privacy violation that has been committed based on the allegations of CID.

WHEREFORE, premises considered, this Commission resolves that the instant case against BDO Unibank, Inc. is hereby **DISMISSED** for lack of merit.

This is without prejudice to the filing of appropriate civil, criminal or administrative cases against BDO Unibank Inc., before any other forum or tribunal, if any.

SO ORDERED.

City of Pasay, Philippines.
05 June 2024.

SGD
JOHN HENRY D. NAGA
Privacy Commissioner

WE CONCUR:

¹²⁸ *Agdeppa v. Office of the Ombudsman*, supra note 56, at 333 citing *De Jesus v. Guerrero III*, 614 Phil. 520, 529.

SGD
LEANDRO ANGELO Y. AGUIRRE
Deputy Privacy Commissioner

SGD
NERISSA N. DE JESUS
Deputy Privacy Commissioner

Copy furnished:

ARA
Data Protection Officer
BDO Unibank, Inc.

XXXXXX
Counsel for BDO Unibank, Inc.

R
Data Protection Officer
Union Bank of the Philippines

ATC
President
Philippine Payments Management Inc./InstaPay

COMPLAINTS AND INVESTIGATION DIVISION
ENFORCEMENT DIVISION
GENERAL RECORDS UNIT
National Privacy Commission